

Relazione di Laboratorio

Bonus 1 – Esplorazione di Nmap

Progetto S11/L5 – Cyber Security & Ethical Hacking

Data: 20 Febbraio 2026

Introduzione

Il presente laboratorio ha come obiettivo l'esplorazione di Nmap (Network Mapper), uno degli strumenti open-source più utilizzati nell'ambito della network discovery e del security auditing. Il laboratorio è suddiviso in due parti principali: la prima dedicata alla comprensione teorica dello strumento tramite le man pages, la seconda alla sua applicazione pratica attraverso la scansione del localhost, della rete locale e di un server remoto autorizzato (scanme.nmap.org).

Parte 1 – Esplorazione di Nmap (man pages)

Cos'è Nmap?

Nmap (Network Mapper) è un tool open-source progettato per il network discovery e il security auditing. Consente di identificare host attivi in una rete, porte TCP/UDP aperte, servizi esposti con relative versioni, sistemi operativi in esecuzione, e di raccogliere numerose altre informazioni tramite tecniche di scanning avanzate e script NSE (Nmap Scripting Engine).

Per cosa viene usato Nmap?

Nmap trova applicazione in molteplici ambiti:

- Ricognizione (recon/enumerazione): identificazione di host attivi, porte aperte e servizi esposti.
- Valutazione della superficie d'attacco: rilevamento di porte, servizi e versioni software potenzialmente vulnerabili.
- Verifica delle esposizioni: individuazione di porte inutilmente aperte o servizi mal configurati.
- Hardening difensivo: controllo che le policy di sicurezza siano correttamente applicate e che la configurazione di rete sia conforme agli standard.
- Penetration testing: prima fase di ricognizione nel ciclo offensivo, per costruire una mappa dettagliata della rete target.

Esempio 1 dalla man page: comando Nmap utilizzato

Dall'Esempio 1 della man page di Nmap, il comando mostrato è:

```
nmap -A -T4 scanme.nmap.org
```

Cosa fa l'opzione -A?

L'opzione -A abilita la modalità di scansione aggressiva (aggressive scan). Questo flag attiva in un'unica istruzione un set di funzionalità avanzate che include: OS detection (rilevamento del sistema operativo), version detection (identificazione delle versioni dei servizi), script scanning tramite NSE (Nmap Scripting Engine) e traceroute. L'utilizzo di -A produce un output molto ricco di informazioni, ma genera anche un traffico di rete più visibile, aumentando la probabilità di essere rilevato da sistemi IDS/IPS.

Cosa fa l'opzione -T4?

L'opzione -T4 imposta un timing template aggressivo (scala da T0 a T5). Questo valore riduce i tempi di attesa tra le sonde inviate, rendendo la scansione notevolmente più rapida rispetto al default T3. Tuttavia, velocità elevata aumenta il rischio di falsi negativi su reti instabili o con alta latenza, e incrementa sensibilmente la probabilità di triggerare meccanismi di difesa come rate-limiting e IDS.

Parte 2 – Scansione delle Porte Aperte

Passo 1 – Scansione del localhost

Comando eseguito:

```
nmap -A -T4 localhost
```

```
[analyst@secOps ~]$ nmap -A -T4 localhost
Starting Nmap 7.97 ( https://nmap.org ) at 2026-02-20 07:26 -0500
Nmap scan report for localhost (127.0.0.1)
Host is up (0.000046s latency).
Other addresses for localhost (not scanned): ::1
Not shown: 998 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.0.8 or later
| ftp-syst:
|   STAT:
| FTP server status:
|   Connected to 127.0.0.1
|   Logged in as ftp
|   TYPE: ASCII
|   No session bandwidth limit
|   Session timeout in seconds is 300
|   Control connection is plain text
|   Data connections will be plain text
|   At session startup, client count was 2
|   vsFTPD 3.0.5 - secure, fast, stable
|_End of status
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_rw-r--r--  1 0      0      0 Mar 26  2018 ftp_test
22/tcp    open  ssh      OpenSSH 10.0 (protocol 2.0)
Service Info: Host: Welcome

Service detection performed. Please report any incorrect results at https://nmap.org/submit/
Nmap done: 1 IP address (1 host up) scanned in 11.67 seconds
[analyst@secOps ~]$
```

Figura 1 – Output della scansione Nmap sul localhost (127.0.0.1)

Porte e servizi aperti rilevati

Dall'output della scansione risultano aperte le seguenti porte:

- **21/tcp (FTP)** – Servizio vsftpd (vsFTPd 3.0.5). Lo script ftp-anon indica che è abilitato il login anonimo (FTP code 230), con traffico di controllo e dati in chiaro (plaintext). Questa configurazione rappresenta un rischio significativo in ambienti di produzione.
- **22/tcp (SSH)** – Servizio OpenSSH 10.0 (protocollo 2.0). Protocollo sicuro, cifratura attiva.

? Nota di sicurezza critica

Il login anonimo FTP è una misconfiguration grave: consente a qualsiasi utente non autenticato di accedere al server FTP. In un ambiente reale, questo vettore deve essere immediatamente chiuso tramite la configurazione del servizio vsftpd (anonymous_enable=NO) e l'accesso limitato via firewall.

Passo 2 – Scansione della rete locale

Preliminarmente si è determinato l'indirizzo IP della VM tramite il comando:

```
ip a
```

```
[analyst@secOps ~]$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: enp0s3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:2f:87:a7 brd ff:ff:ff:ff:ff:ff
    altname enx0800272f87a7
    inet 10.0.2.15/24 metric 1024 brd 10.0.2.255 scope global dynamic enp0s3
        valid_lft 85683sec preferred_lft 85683sec
    inet6 fd17:625c:f037:2:a00:27ff:fe2f:87a7/64 scope global dynamic mngtmpaddr noprefixroute
        valid_lft 86311sec preferred_lft 14311sec
    inet6 fe80::a00:27ff:fe2f:87a7/64 scope link proto kernel_ll
        valid_lft forever preferred_lft forever
```

Figura 2 – Output del comando 'ip a': indirizzo IP e subnet mask della VM

? A quale rete appartiene la VM?

La VM appartiene alla rete 10.0.2.0/24 (subnet mask 255.255.255.0), avendo indirizzo IPv4 10.0.2.15/24. L'indirizzo di broadcast è 10.0.2.255.

Successivamente è stata eseguita la scansione dell'intera subnet con il comando:

```
nmap -A -T4 10.0.2.0/24
```

```
[analyst@secOps ~]$ nmap -A -T4 10.0.2.0/24
Starting Nmap 7.97 ( https://nmap.org ) at 2026-02-20 07:58 -0500
Nmap scan report for 10.0.2.2
Host is up (0.00034s latency).
All 1000 scanned ports on 10.0.2.2 are in ignored states.
Not shown: 1000 closed tcp ports (conn-refused)

Nmap scan report for 10.0.2.3
Host is up (0.00040s latency).
All 1000 scanned ports on 10.0.2.3 are in ignored states.
Not shown: 1000 closed tcp ports (conn-refused)

Nmap scan report for 10.0.2.15
Host is up (0.00027s latency).
Not shown: 998 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.0.8 or later
| ftp-syst:
|   STAT:
|   FTP server status:
|     Connected to 10.0.2.15
|     Logged in as ftp
|     TYPE: ASCII
|     No session bandwidth limit
|     Session timeout in seconds is 300
|     Control connection is plain text
|     Data connections will be plain text
|     At session startup, client count was 4
|     vsFTPD 3.0.5 - secure, fast, stable
|_End of status
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_--rw-r--r--  1 0          0   0 Mar 26  2018 ftp_test
22/tcp    open  ssh      OpenSSH 10.0 (protocol 2.0)
Service Info: Host: Welcome

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 256 IP addresses (3 hosts up) scanned in 56.22 seconds
```

Figura 3 – Output della scansione Nmap sulla rete locale 10.0.2.0/24

? Quanti host sono attivi? Quali indirizzi IP?

La scansione ha rilevato 3 host attivi ("3 hosts up") nella subnet 10.0.2.0/24: • 10.0.2.2 – host attivo, nessuna porta TCP aperta rilevata (1000 porte chiuse, conn-refused) • 10.0.2.3 – host attivo, nessuna porta TCP aperta rilevata • 10.0.2.15 – la VM in analisi, con porte 21/tcp (FTP – vsftpd 3.0.5) e 22/tcp (SSH – OpenSSH 10.0) aperte

Passo 3 – Scansione del server remoto scanme.nmap.org

Prima di eseguire la scansione è stato verificato il messaggio sul sito scanme.nmap.org, che conferma l'autorizzazione esplicita per test di questo tipo:

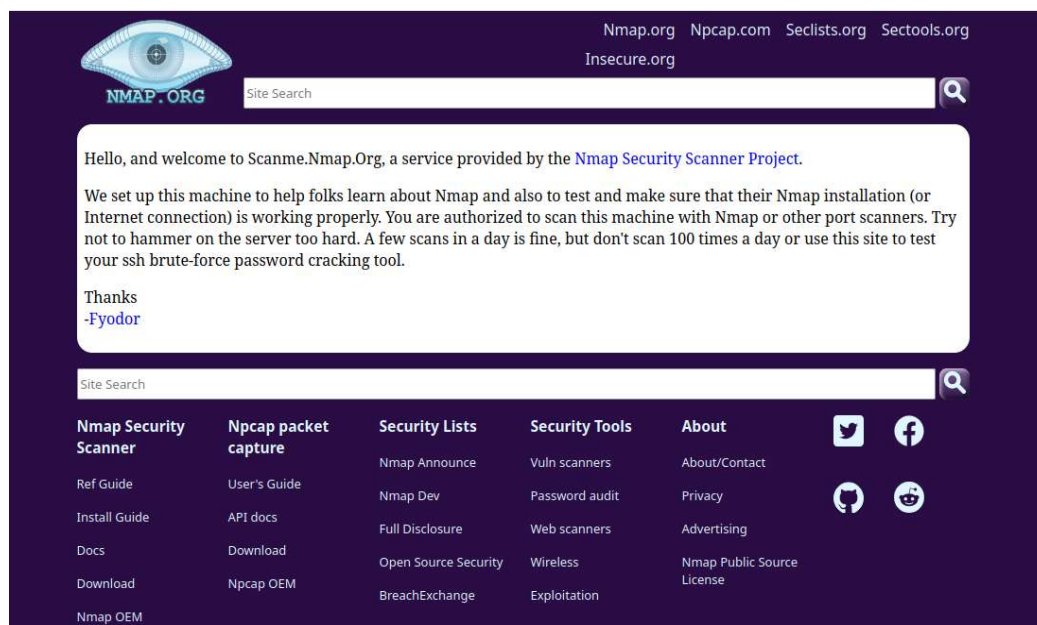


Figura 4 – Pagina web di scanme.nmap.org: autorizzazione esplicita alle scansioni

? Qual è lo scopo di questo sito?

scanme.nmap.org è un host messo a disposizione dal Nmap Security Scanner Project con finalità esclusivamente didattiche e di test. Consente agli utenti di eseguire scansioni Nmap in modo autorizzato per imparare ad usare lo strumento e verificare che la propria installazione e connessione funzionino correttamente. Il servizio è pensato per un utilizzo moderato (poche scansioni al giorno) e vieta categoricamente attività brute force o scansioni aggressive ripetute.

Comando eseguito:

```
nmap -A -T4 scanme.nmap.org
```

```
[analyst@secOps ~]$ nmap -A -T4 scanme.nmap.org
Starting Nmap 7.97 ( https://nmap.org ) at 2026-02-20 09:53 -0500
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.20s latency).
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:91ff:fe18:bb2f
Not shown: 996 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   1024 ac:00:a0:1a:82:ff:cc:55:99:dc:67:2b:34:97:6b:75 (DSA)
|   2048 20:3d:2d:44:62:2a:b0:5a:9d:b5:b3:05:14:c2:a6:b2 (RSA)
|   256 96:02:bb:5e:57:54:1c:4e:45:2f:56:4c:4a:24:b2:57 (ECDSA)
|_  256 33:fa:91:0f:e0:e1:7b:1f:6d:05:a2:b0:f1:54:41:56 (ED25519)
80/tcp    open  http         Apache httpd 2.4.7 ((Ubuntu))
|_ http-title: Go ahead and ScanMe!
|_ http-server-header: Apache/2.4.7 (Ubuntu)
|_ http-favicon: Nmap Project
9929/tcp  open  nping-echo   Nping echo
31337/tcp open  tcpwrapped
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 31.42 seconds
```

Figura 5 – Output della scansione Nmap su scanme.nmap.org

Risultati della scansione – scanme.nmap.org

Porta	Stato	Servizio / Dettagli
22/tcp	APERTA	SSH – OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)
80/tcp	APERTA	HTTP – Apache httpd 2.4.7 (Ubuntu), title: Go ahead and ScanMe!
9929/tcp	APERTA	nping-echo – Nping echo service
31337/tcp	APERTA	tcpwrapped – connessione gestita/chiusa da wrapper o ACL
25/tcp	FILTRATA	SMTP – bloccata da firewall/policy di rete
135/tcp	FILTRATA	MSRPC – bloccata
139/tcp	FILTRATA	NetBIOS-SSN – bloccata
445/tcp	FILTRATA	Microsoft-DS – bloccata
4444/tcp	FILTRATA	krb524 – bloccata
996 porte	FILTRATE	Nessuna risposta (no-response) – firewall attivo

? Indirizzo IP del server scanme.nmap.org

45.33.32.156 (risoluzione DNS confermata da Nmap: scanme.nmap.org → 45.33.32.156)

? Sistema operativo rilevato

L'host risulta Linux (Nmap riporta: Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel). I banner esposti dai servizi rilevati di OpenSSH e Apache risultano coerenti con una distribuzione Ubuntu; tuttavia l'identificazione del dettaglio "Ubuntu" è da considerarsi indicativa (derivata da fingerprint/banner) e non una conferma assoluta.

Domanda di Riflessione – Nmap: strumento difensivo e offensivo

Nmap è uno strumento di rete a duplice valenza: fondamentale per la sicurezza difensiva, ma potenzialmente pericoloso nelle mani di un attore malevolo. Di seguito si analizzano entrambe le prospettive.

Come può Nmap aiutare con la sicurezza della rete

In ambito difensivo, Nmap permette di:

- Ridurre la superficie d'attacco: identifica porte e servizi esposti (anche non previsti), rendendo possibile disabilitare servizi inutili o limitarne l'accesso tramite firewall e ACL.
- Eseguire inventario e controllo dell'esposizione: mappa host attivi, ruoli e servizi disponibili, utile per asset management e per scoprire dispositivi shadow IT non autorizzati.
- Verificare hardening e conformità: confrontando i risultati nel tempo è possibile rilevare variazioni non autorizzate (nuove porte aperte, versioni cambiate, servizi riattivati).
- Supportare la gestione delle vulnerabilità: tramite version detection e script NSE, Nmap aiuta a individuare servizi potenzialmente vulnerabili o misconfiguration (es. login anonimo su FTP, servizi legacy come Telnet).
- Validare segmentazione e regole di filtering: la presenza di porte 'filtered' o 'closed' consente di controllare l'efficacia di firewall, NAT e policy di rete.

Come può Nmap essere usato da un attore malevolo

Lo stesso set di funzionalità può essere sfruttato in modo offensivo:

- Ricognizione mirata (recon): individuare rapidamente host attivi, porte aperte e servizi, costruendo una mappa della rete utile per pianificare l'attacco.
- Selezione di vettori d'attacco e exploit: identificando servizi e versioni, un attaccante può cercare vulnerabilità note o configurazioni deboli da sfruttare.
- Fingerprinting del sistema: OS detection e banner grabbing permettono di conoscere lo stack tecnologico (distro, web server, versione SSH), facilitando l'uso di tecniche e payload più efficaci.

- Individuazione di target ad alto valore: scannerizzando subnet, un attaccante può trovare server esposti, apparati di management, servizi critici e porte 'rare' utili per pivoting e persistence.
- Movimenti laterali: una volta ottenuto l'accesso iniziale, la scansione interna accelera l'enumerazione e l'espansione verso altri host/servizi della rete compromessa.

Conclusione critica

Nmap non è intrinsecamente 'buono' o 'cattivo': è un abilitatore di conoscenza. In ambito difensivo è uno strumento irrinunciabile per audit, hardening e monitoraggio continuo della superficie esposta. In ambito offensivo rappresenta uno dei primi strumenti impiegati per trasformare una rete sconosciuta in una superficie d'attacco dettagliata e sfruttabile. La distinzione non è nello strumento, ma nell'autorizzazione e nell'intento di chi lo utilizza. Per questo motivo, in ambito professionale, l'utilizzo di Nmap deve essere sempre documentato, autorizzato e limitato al perimetro concordato nel contratto di penetration testing o audit.